Insecure Direct Object References / Missing Ownership Checks

SHOP-005 — Vulnerability Assessment Finding Report

Field	Value
Finding ID	SHOP-005
Product	PHPGurukul Online Shopping Portal
Version	V2.0 package (product page labelled V2.1); SQL dump dated 2025-01-02
Developer	Anuj Kumar / PHPGurukul
Assessment Target	http://localhost:8080/shopping/ (authorized local laboratory; localhost only)
Assessment Date	2026-11-01
Severity	Medium
CVSS	5.1 / CVSS:4.0 AV:N/AC:L/PR:L/UI:N/VC:L/VI:L/VA:L
CWE	CWE-639 (Authorization Bypass Through User-Controlled Key)
OWASP	A01:2021 Broken Access Control
CVE Verification	No matching publicly assigned CVE was identified for this specific finding/version during the research performed. (No matching CVE)
Affected URL	category.php, search-result.php, sub-category.php, product-details.php (wishlist), pending-orders.php
Affected Parameter	pid, id (GET)
Affected Role	User
Authentication	User session

Executive Summary

Several operations act on client-supplied object ids without verifying that the object belongs to the requesting user.

Technical Description

e.g. category.php:32 insert into wishlist(userId,productId) values('$_SESSION[id]','$_GET[pid]') trusts pid; pending-orders.php:12 deletes an order by $_GET['id']; the order-tracking lookup (SHOP-006) exposes others' orders via SQLi. These keys are also injection points.

Root Cause Analysis

Object access keyed on request input with no ownership validation.

Preconditions

A user session (or none, for the order-tracking case).

Proof of Concept — Step-by-Step Reproduction

1. As a logged-in user, add an arbitrary productId to the wishlist via category.php?action=wishlist&pid=<any>.
2. pending-orders.php?id=<n> targets an order row by id; combined with SHOP-006, order data of other users is reachable.

HTTP Request

```
GET /shopping/category.php?action=wishlist&pid=9999 (arbitrary productId accepted)
```

HTTP Response (evidence)

```
Row inserted referencing the attacker-chosen id; no ownership check performed.
```

Proof of Concept & Visual Evidence

This finding is confirmed by source-code review and (where noted) database inspection; see the referenced primary evidence. No screenshot is required for a static/offline finding.

Actual Security Impact

Cross-object manipulation and, via the order-tracking SQLi, unauthorized access to other users' order data.

Exploitation Complexity

Low.

Attack Scenario

A user references or affects records they do not own.

Remediation

Validate that each referenced object belongs to the session user before any read/write; parameterize queries.

Secure Code Example

```
// verify: SELECT 1 FROM orders WHERE id=? AND userId=? before delete/view
```

Retesting Procedure

Operations on non-owned ids must be rejected.

References

- CWE-639; OWASP A01
- Evidence: source-review/critical-code-paths.md; overlaps SHOP-006

Final Conclusion

Confirmed by source (and dynamically for the order-tracking case). Medium.

Authorized local-laboratory assessment. Evidence chain sealed (evidence/shopping-portal/SEAL). Draft for human review — not auto-submitted. Secrets/PII in evidence are lab demo data; redact in externally-shared copies.